ПР3. Расследование инцидента в цифровой образовательной среде

Условная образовательная организация «Школа цифровых практик»

Индивидуальный вариант № 8: временная линия

Джамалова Сабина Шахиновна, группа МПИНФ-261м

Цель: по журналам почты, аутентификации и LMS восстановить последовательность событий 15.09.2026, отделить факты от гипотез, определить масштаб инцидента и предложить соразмерные меры без обвинения педагога. Все данные условные. Внутренними считаются адреса 10.20.x.x, внешний адрес 203.0.113.77 не принадлежит школьной сети.

1. Подозрительные события

Источник	ID	Что произошло	Почему требует внимания
Почта	M02	в 08:41:37 доставлено письмо с внешнего адреса support@edu-help.example «Срочно подтвердите учётную запись LMS» со ссылкой на lms-confirm.edu-help.example	отправитель и домен не школьные, в письме срочность и просьба подтвердить учётную запись: типичные признаки социальной инженерии
Почта	M03	в 08:44:03 с компьютера 10.20.5.14 выполнен переход по ссылке из M02	ссылка из подозрительного письма открыта; это факт перехода, но не доказательство того, что был введён пароль
Аутентификация	A02	в 08:47:26 неудачный вход в LMS (неверный пароль) с внешнего IP 203.0.113.77	первое обращение с внешнего адреса, который не принадлежит школе; перед успешным входом была неудачная попытка
Аутентификация	A03	в 08:47:41, через 15 секунд, успешный вход в LMS с 203.0.113.77	учётная запись педагога использована с внешнего IP сразу после неудачной попытки
Аутентификация	A04	в 08:47:42 создана сессия SES-7781 с 203.0.113.77	сессия могла остаться активной и после смены пароля
LMS	L02	в 08:51:12 экспорт участников курса course-INF-7A (31 запись) с 203.0.113.77	выгрузка персональных данных обучающихся с внешнего IP
LMS	L03, L04	в 08:54:05 и 08:54:39 изменены оценки: student-S014 (4 -> 5), student-S022 (3 -> 5), IP 203.0.113.77	нарушена целостность оценок; изменения сделаны вне школьной сети
LMS	L05	в 08:57:10 создан API-токен token-T91 с правами чтения курса и изменения оценок, IP 203.0.113.77	токен может сохранить доступ после смены пароля и завершения сессии

Источник	ID	Что произошло	Почему требует внимания
LMS	L06	в 09:03:18 скачаны 12 файлов задания task-2026-08-20, IP 203.0.113.77	возможна утечка учебных материалов; действие совершено с внешнего IP

Не вызывают подозрений сами по себе: A01, L01 (обычная работа с 10.20.5.14 до письма), M01 и M04 (служебные письма школьных адресов), A05 (другой педагог, внутренний IP 10.20.5.22). Записи A06 и L07-L09 сделаны с внутреннего IP 10.20.5.14 после 09:14; они не подозрительны, но требуют уточнения (см. раздел 5).

2. Временная линия

Время	ID	Источник	Событие	Значение
08:41:37	M02	Почта	доставлено письмо с внешнего адреса с просьбой «срочно подтвердить учётную запись LMS»	возможное начало цепочки; самое раннее событие, которое можно связать с инцидентом
08:44:03	M03	Почта	с 10.20.5.14 открыта ссылка из M02	возможная передача данных на внешнюю страницу; 3 мин 23 с до первого входа извне
08:47:26	A02	Аутентификация	неудачный вход с 203.0.113.77	первое обращение с внешнего IP
08:47:41	A03	Аутентификация	успешный вход с 203.0.113.77 (в 08:47:42 создана сессия SES-7781, A04)	чужой адрес получил доступ к учётной записи
08:51:12	L02	LMS	экспорт 31 записи участников курса	затронуты персональные данные обучающихся
08:54:05	L03	LMS	оценка student-S014: 4 -> 5	изменены данные об успеваемости
08:54:39	L04	LMS	оценка student-S022: 3 -> 5	второе изменение за 34 секунды, схема повторяется
08:57:10	L05	LMS	создан токен token-T91 (чтение курса, изменение оценок)	закрепление доступа
09:03:18	L06	LMS	скачаны 12 файлов задания	последнее событие с 203.0.113.77 в имеющихся журналах
09:14:37	A06	Аутентификация	вход с 10.20.5.14 (далее L07-L09: просмотр курса, журнала и оценки S014)	педагог работает локально; дальше в 09:25 он сам обратился в ИТ-службу

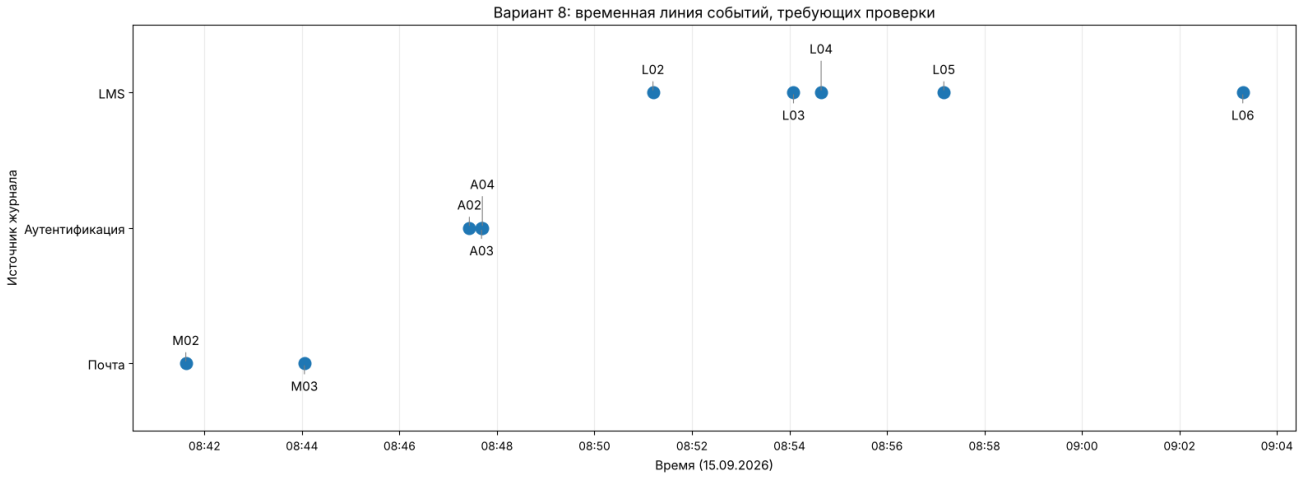


Рисунок 1. Временная линия событий варианта 8, требующих проверки

3. Факты, гипотеза и дополнительные проверки

Подтверждённые факты

1. Письмо с внешнего адреса support@edu-help.example, просившее срочно подтвердить учётную запись LMS, доставлено педагогу в 08:41:37 (M02).

2. В 08:44:03 с компьютера 10.20.5.14 зафиксирован переход по ссылке из этого письма (M03).

3. В 08:47:26 с внешнего IP 203.0.113.77 была неудачная попытка входа под учётной записью teacher.ivanova, в 08:47:41 успешный вход, в 08:47:42 создана сессия SES-7781 (A02, A03, A04).

4. С того же IP в 08:51:12-09:03:18 в LMS выполнены экспорт 31 записи участников курса, изменение двух оценок, создание токена token-T91 и скачивание 12 файлов (L02-L06).

5. До письма и после 09:14 действия под этой учётной записью выполнялись с внутреннего IP 10.20.5.14 (A01, L01, A06, L07-L09).

6. От перехода по ссылке до первого входа с внешнего IP прошло 3 минуты 23 секунды (M03 -> A02).

Что не является фактом

- что пароль был введён на странице по ссылке из M02: журналы фиксируют только переход, но не ввод данных;

- что письмо M02 стало причиной входа A03: совпадение по времени не доказывает причинную связь;

- кто именно выполнял действия с 203.0.113.77, и что педагог к ним не причастен либо причастен: журналы этого не показывают;

- что действия L02-L06 относятся именно к сессии SES-7781: в журнале LMS нет номера сессии, есть только учётная запись и IP;

- что экспортированные данные, файлы и токен кем-то использованы дальше;

- что изменены только две оценки: в имеющихся фрагментах другие изменения не видны, но полнота журнала не подтверждена.

Рабочая гипотеза

Учётная запись teacher.ivanova была скомпрометирована после перехода по ссылке из письма M02: пароль мог быть введён на поддельной странице, после чего с адреса 203.0.113.77 выполнен вход и действия L02-L06. Это гипотеза, а не установленный факт. Альтернативная гипотеза: пароль был получен другим способом (например, повторно использован в другом сервисе), а письмо M02 совпало с ним по времени.

Источник	Какой вопрос поможет закрыть
Почтовый шлюз	кому ещё доставлено M02 и кто открывал ссылку; приходили ли похожие письма раньше
Прокси, DNS, межсетевой экран	обращался ли ПК 10.20.5.14 к lms-confirm.edu-help.example, были ли отправлены данные, в какое время
Журналы аутентификации и MFA	чем отличалась попытка A02, откуда ещё были входы за предыдущие дни, менялся ли пароль
Журнал LMS и API	использовался ли token-T91 после создания, были ли другие действия с 203.0.113.77 после 09:03:18, есть ли другие изменения оценок
Разговор с педагогом	переходил ли по ссылке, вводил ли пароль, использует ли такой же пароль в других сервисах

4. Масштаб, локализация и восстановление

Что могло быть затронуто

Объект	Что подтверждено	Что неизвестно
Учётная запись teacher.ivanova	вход с внешнего IP и сессия SES-7781 (A03, A04)	известен ли пароль третьим лицам и где ещё он используется
Данные обучающихся	экспорт 31 записи курса course-INF-7A (L02)	какие поля были в файле и ушёл ли он дальше
Оценки	изменены student-S014 (4 -> 5) и student-S022 (3 -> 5) (L03, L04)	есть ли другие изменения, в том числе через токен
Файлы	скачаны 12 файлов задания task-2026-08-20 (L06)	были ли среди них материалы, которые нельзя раскрывать до срока

Объект	Что подтверждено	Что неизвестно
Токен token-T91	создан с правами чтения курса и изменения оценок (L05)	использовался ли и где хранится
Рабочее место 10.20.5.14	с него открыта ссылка из M02 (M03)	не загрузилось ли что-либо с поддельной страницы

Меры локализации и порядок выполнения

1. Отозвать token-T91 и завершить сессию SES-7781 и все активные сессии учётной записи: смена пароля сама по себе токен и сессию не закрывает, поэтому это делается первым.

2. Сбросить пароль через проверенный канал (лично или по известному школе телефону) и включить второй фактор. Пока идёт проверка, права на изменение оценок можно ограничить.

3. Заблокировать адрес 203.0.113.77 на границе сети и домен edu-help.example в почте и на прокси; удалить письмо M02 из ящиков других получателей.

4. Сохранить журналы без изменений (выгрузить записи A02-A04 и L02-L06), чтобы не потерять доказательства.

5. Проверить остальные токены, сессии и курсы этого педагога, а также компьютер 10.20.5.14.

6. Восстановить оценки S014 и S022 по доверенному источнику (история изменений в LMS, резервная копия, черновик педагога) и зафиксировать исправление.

7. Не отключать всю LMS: занятия других педагогов и классов продолжаются, меры направлены на одну учётную запись.

Критерии безопасного восстановления работы преподавателя

- токен token-T91 отозван, других неизвестных токенов и активных сессий нет;

- пароль сменён на новый, не совпадающий с прежним и с паролями в других сервисах, включён второй фактор;

- оценки S014 и S022 сверены с доверенным источником и исправлены с записью в журнале изменений;

- в течение 24-72 часов после смены нет входов и действий с внешних адресов;

- компьютер 10.20.5.14 проверен, письмо M02 удалено у всех получателей;

- педагог прошёл короткий инструктаж и знает, как сообщать о подозрительных письмах.

Кто оценивает необходимость уведомления Роскомнадзора

Необходимость уведомления оценивает ответственный за организацию обработки персональных данных в школе совместно с директором и ИТ-службой, поскольку экспорт 31 записи (L02) мог затронуть персональные данные обучающихся. Уведомление направляет школа как оператор персональных данных, а решение принимает руководитель на основании заключения ответственного. Сроки и порядок нужно сверить с действующей редакцией ст. 21 ч. 3.1 152-ФЗ.

5. Индивидуальный вариант № 8: временная линия

По номеру варианта из общего файла pr_03_events_all_variants.csv отобрано 14 событий варианта 8 (M02, M03, A02-A04, L02-L06, A06, L07-L09); события других вариантов не использовались. Ноутбук отнёс к контуру инцидента 10 из них (08:41:37-09:03:18).

Задание 1. Ключевые события инцидента

ID	Время	Ключевое событие	Почему ключевое
M02	08:41:37	письмо с внешнего адреса с просьбой подтвердить учётную запись	возможная точка входа в сценарий
M03	08:44:03	переход по ссылке из M02 с 10.20.5.14	связывает почту с дальнейшей хронологией
A02-A04	08:47:26-08:47:42	неудачный вход, успешный вход и сессия SES-7781 с 203.0.113.77	первый доступ с внешнего адреса
L02	08:51:12	экспорт 31 записи участников	затронута конфиденциальность
L03, L04	08:54:05, 08:54:39	изменение оценок S014 и S022	затронута целостность
L05	08:57:10	создан token-T91	возможность сохранить доступ
L06	09:03:18	скачано 12 файлов	последнее подозрительное событие в журналах
A06	09:14:37	вход с 10.20.5.14	граница: дальше работа идёт с внутреннего IP

Задание 2. Подтверждённый интервал подозрительных действий

Подтверждённый журналами интервал действий с внешнего IP 203.0.113.77: с 08:47:26 (A02) до 09:03:18 (L06), то есть 15 минут 52 секунды. Если считать от письма, интервал событий, требующих проверки, составляет 08:41:37-09:03:18 (21

минута 41 секунда), но первые два события (M02, M03) подозрительны косвенно: сами по себе они не доказывают злоумышленных действий. Границы интервала нельзя считать границами доступа: окончание в 09:03:18 означает лишь последнюю запись в имеющихся журналах. Сессия SES-7781 и токен token-T91 не закрыты по данным журналов, поэтому доступ мог продолжаться и позже; журналы после 09:14:37 показывают только действия с внутреннего IP.

Задание 3. Может ли компрометация начаться раньше?

Да, может. Во-первых, первое подозрительное действие в журнале (A02, 08:47:26) не равно моменту компрометации: если пароль был введён на странице по ссылке из M02, он мог попасть к третьему лицу уже около 08:44, то есть за 3 минуты 23 секунды до A02. Во-вторых, перед успешным входом была неверная попытка (A02), и только через 15 секунд пароль подошёл (A03): это говорит, что верный пароль мог быть получен не сразу или другим путём, например из другого сервиса, и тогда доступ был подготовлен раньше письма. В-третьих, имеющиеся журналы начинаются в 07:58 и охватывают одно утро; в них до 08:41 нет подозрительных событий, но отсутствие записи не доказывает отсутствия события. Поэтому самая ранняя точка, которую подтверждают данные при фишинговой гипотезе, это 08:41:37 (M02), а более раннее начало нужно проверять по журналам предыдущих дней: входы teacher.ivanova с внешних адресов, неудачные попытки, смена пароля, прокси-журнал.

6. Сообщение педагогам

Коллеги, сегодня утром в журнале одного из курсов в LMS появились оценки, которые педагог не выставлял, и ИТ-служба сейчас проверяет безопасность доступа. Перед этим на школьную почту приходило письмо «Срочно подтвердите учётную запись LMS» с неизвестного адреса; связано ли оно с произошедшим, пока выясняется. Просим не переходить по ссылкам из таких писем и не вводить по ним пароль. Если вы получили или открывали такое письмо, не удаляйте его и сообщите в ИТ-службу по обычному каналу связи. Пожалуйста, проверьте свои оценки за сегодня, а если что-то кажется странным, ничего не исправляйте самостоятельно, чтобы не стереть следы, а сразу напишите в ИТ-службу. Занятия идут по расписанию, при необходимости ИТ-служба поможет сменить пароль. Мы благодарны каждому, кто сообщает о подозрительных письмах и входах: чем раньше мы узнаём, тем проще всё исправить.

7. Педагогический разбор

Как организовать разговор и разбор без обвинения

Разговор лучше провести лично и в спокойной обстановке, начав с благодарности за то, что педагог сам обратился в ИТ-службу в 09:25: это пример правильного поведения. Далее вместе идти по временной линии и задавать открытые вопросы: что вы делали утром, видели ли письмо, открывали ли ссылку, вводили ли пароль, использовали ли его где-то ещё. Нельзя формулировать «вы виноваты» или «зачем вы нажали», потому что по журналам нельзя утверждать, что именно педагог выполнял подозрительные действия, а страх наказания приведёт к тому, что о следующем случае сообщат позже. Цель разбора: понять, какие условия сделали инцидент возможным, и исправить их.

Системные меры

Тип	Мера	Обоснование
Техническая (приоритетная)	обязательная MFA для педагогов, уведомление о входе с нового IP, подтверждение при создании API-токена	в записях A02-A03 доступ получен по одному паролю за 15 секунд; второй фактор не позволил бы войти без устройства педагога, а токен L05 не создавался бы без подтверждения
Организационная	правило раннего сообщения: о подозрительном письме или необычном входе сообщать сразу, без последствий для сообщившего	педагог обратился сам в 09:25; такое поведение сокращает время реагирования
Образовательная	короткий практикум по признакам фишинга на примере M02 (чужой домен, срочность, просьба подтвердить учётную запись)	признаки видны в самом письме и легко запоминаются

Как сохранить работу преподавателя и занятия на время реагирования

Занятия не отменяются. На время проверки методист или коллега проводит урок по подготовленным материалам, а копии заданий предоставляет ИТ-служба. Педагог получает новый пароль и второй фактор после личной проверки, а до этого ведёт оценки на бумаге и вносит их в LMS после восстановления доступа. Курс может быть временно переведён в режим просмотра, чтобы новые изменения оценок были невозможны, но обучающиеся продолжают работать с материалами.

8. Вывод

Журналы показывают цепочку: письмо с внешнего адреса (M02), переход по ссылке (M03), вход с внешнего IP 203.0.113.77 (A02-A04) и пять действий в LMS в течение 15 минут 52 секунд (L02-L06). Подтверждены экспорт 31 записи, изменение двух оценок, создание токена и скачивание 12 файлов; причина входа и личность действовавшего остаются гипотезой. Первым нужно отозвать токен token-T91 и закрыть сессии, потому что смена пароля сама по себе их не отключает, затем восстановить оценки по доверенному источнику. Системная мера, которая лучше всего снижает риск, это обязательная MFA для педагогов вместе с культурой раннего сообщения без обвинения.